

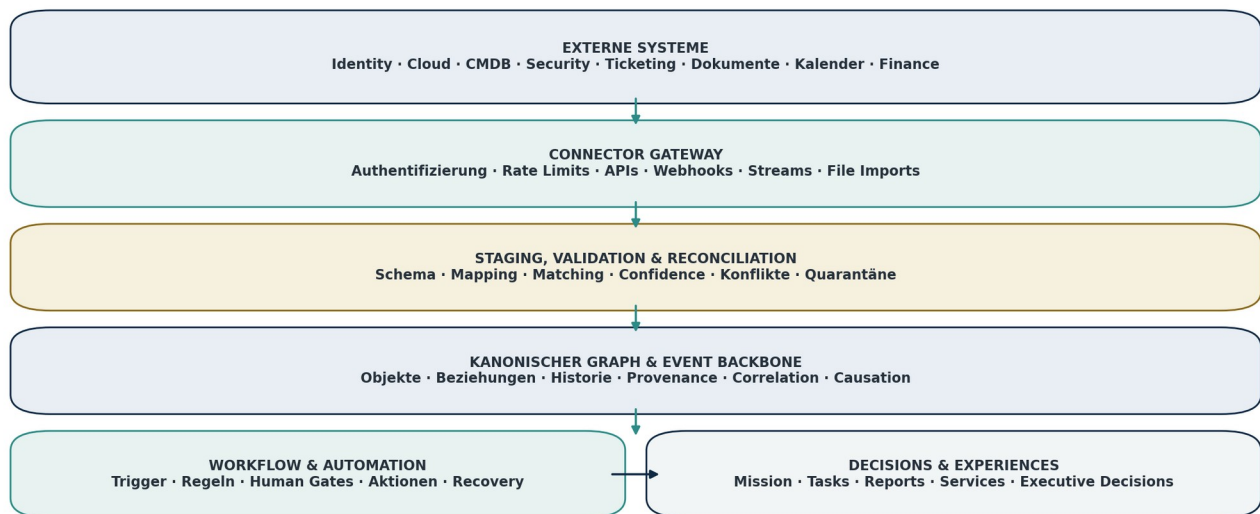
## PRODUKTKONZEPT 17

# Integrationen, Automatisierung & Workflow-Designer

Das sichere Nervensystem der Plattform: externe Signale verstehen, kanonisch verbinden,  
zuverlässig automatisieren und in nachvollziehbare ISMS-Entscheidungen  
übersetzen.

**Integrationsarchitektur: von Quellsystemen über Reconciliation und Events bis zu Workflows und Entscheidungen**

## Integrations- und Automatisierungs-Nervensystem



Prinzip: Quellen bleiben Quellen; die Plattform übersetzt Signale in belastbare ISMS-Entscheidungen.

**ARBEITSBEZEICHNUNG** ISMS Managed Service Platform

**VERSION** 1.0

**STATUS** Erstellt

**STAND** 22.07.2026

**ABHÄNGIGKEITEN** Dokument 00 bis 16

# Dokumentauftrag & Verbindlichkeit

Dokument 17 ist die kanonische Quelle für Connectoren, Connection Instances, Data Contracts, Mappings, Synchronisation, Eventverarbeitung, Reconciliation, Workflow-Definitionen, Automatisierungs-Blueprints, Human Gates und den operativen Connector-Betrieb. Nachfolgende Dokumente konkretisieren Technologie, Sicherheit, KI und Umsetzung, dürfen diese Semantik aber nicht still verändern.

| Steuerungsfeld     | Festlegung                                                                                                                                                               |
|--------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Dokument-ID        | 17                                                                                                                                                                       |
| Status             | Erstellt – Version 1.0                                                                                                                                                   |
| Owner              | Product Architecture / Integration & Automation Owner                                                                                                                    |
| Gültigkeit         | Bis zur freigegebenen Nachfolgeversion                                                                                                                                   |
| Datenstatus        | Alle Connector-Payloads, Unternehmen, Personen, Incidents, Tickets und Preise der Demo sind synthetisch.                                                                 |
| Änderungskontrolle | Änderungen an Data Contracts, Events, Reconciliation, Workflow-Semantik, Human Gates oder externen Schreibaktionen benötigen Version, Impactanalyse, Tests und Freigabe. |

## Inhalt

1 Auftrag · 2 Summary · 3 Verfassung · 4 Zielbild · 5 Objekte · 6 Muster · 7 Lifecycle · 8 Auth · 9 Contracts · 10 Mapping · 11 Reconciliation · 12 Sync · 13 Events · 14 Connector-Katalog · 15–20 Connector-Familien · 21 Generic REST · 22 Import/Export · 23 Designer · 24 Regeln · 25 Aktionen · 26 Human Gates · 27 Bibliothek · 28 Managed Services · 29 Checkpoints · 30 Recovery · 31 Operations · 32 Limits · 33 Versionierung · 34 Security · 35 Tests · 36 Demo Hub · 37 UI · 38 KPIs · 39–40 Szenarien · 41–48 Governance, Entscheidungen, Quellen und Abhängigkeiten

# 1. Auftrag und Abgrenzung

Dokument 17 ist die kanonische fachlich-technische Quelle für Integrationen, Connectoren, kontrollierte Datenübernahme, Synchronisation, Ereignisverarbeitung, Automatisierungsregeln, wiederverwendbare Workflows und deren operativen Betrieb auf der ISMS Managed Service Plattform. Es konkretisiert, wie externe Informationen aus Identitäts-, Asset-, Cloud-, Security-, Ticketing-, Dokumenten-, Kalender-, Reise- und Business-Systemen sicher in den digitalen Unternehmenszwilling gelangen und wie daraus nachvollziehbare Aufgaben, Entscheidungen, Evidenzen, Warnungen und Managed-Service-Arbeit entstehen.

Das Dokument beantwortet insbesondere:

- Wie wird die Plattform zum Nervensystem des ISMS, ohne bestehende Quellsysteme unnötig zu ersetzen?
- Welche Integrationsarten werden unterstützt und wann sind API, Webhook, Delta-Synchronisation, Streaming, Dateiimport oder manueller Fallback geeignet?
- Wie werden externe Daten in kanonische Objekte aus Dokument 07 überführt, ohne Herkunft und Bedeutung zu verlieren?
- Wie werden Dubletten, widersprüchliche Werte, veraltete Informationen und unsichere Zuordnungen behandelt?
- Wie entstehen aus Ereignissen zuverlässige, wiederholbare und revisionsfähige Automatisierungen?
- Wie können Berater Workflows über viele Mandanten standardisieren, ohne kundenspezifische Scope-, Rollen- oder Freigaberegeln zu überschreiben?
- Wie werden Fehler, Rate Limits, Verbindungsabbrüche, API-Änderungen und ausgefallene Webhooks erkannt und behoben?
- Wie bleibt jeder automatisierte Schritt erklärbar, reversibel und unter menschlicher Kontrolle?
- Welche Connectoren und Automatisierungen müssen im Prototyp real funktionieren und welche dürfen mit synthetischen Daten simuliert werden?

Nicht Gegenstand dieses Dokuments sind die endgültige Cloud-, Datenbank-, Queue- oder Laufzeittechnologie, die in Dokument 18 festgelegt wird; das vollständige Sicherheits-, Datenschutz- und Berechtigungsdesign aus Dokument 19; die Auswahl konkreter KI-Modelle aus Dokument 20A; die Agentenfirma aus Dokument 20B; sowie die Repository- und Implementierungsregeln aus Dokument 20C. Dieses Dokument legt jedoch die Anforderungen fest, die diese Nachfolger erfüllen müssen.

## 2. Executive Summary

Die Plattform soll externe Systeme nicht nachbauen, sondern **deren Signale in belastbare Sicherheitsentscheidungen übersetzen**. Ein SIEM erkennt Vorfälle, ein Schwachstellenscanner findet technische Schwächen, eine CMDB kennt Konfigurationselemente, ein Ticketing-System organisiert operative Arbeit und ein Dokumentensystem verwaltet Dateien. Die ISMS Managed Service Plattform verbindet diese Informationen mit Geschäftskontext, Scope, Risiken, Controls, Verantwortungen, Zielprofilen und Services. So entsteht aus verteilten Daten ein handlungsfähiges Gesamtbild.

Die Integrationsarchitektur folgt fünf Schritten:

- 1. Verbinden:** Eine Connection Instance authentifiziert sich minimal berechtigt am Quellsystem.
- 2. Verstehen:** Ein Connector erfasst Schema, Fähigkeiten, Grenzen, Datenherkunft und zulässige Operationen.
- 3. Übersetzen:** Rohdaten werden gestaged, validiert, normalisiert und auf kanonische Objekte sowie Beziehungen gemappt.
- 4. Abgleichen:** Matching, Reconciliation, Confidence und menschliche Freigaben verhindern stille Fehlzuordnungen.
- 5. Aktivieren:** Freigegebene Änderungen erzeugen Graph-Updates, Events, Workflows, Entscheidungen, Evidenzen oder Reports.

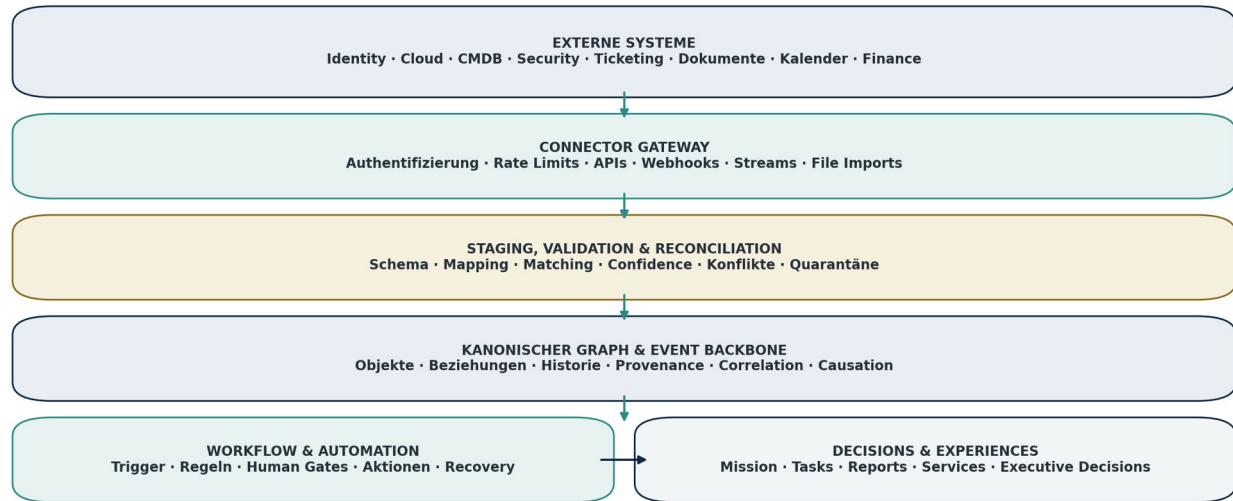
Die Plattform unterstützt sechs Integrationsmuster: manuelle Eingabe, strukturierter Dateiimport, geplante Synchronisation, Delta-Synchronisation, Webhooks sowie Ereignis- oder Datenstreams. Jede Integration besitzt einen sichtbaren Gesundheitszustand, eine Datenfrische, ein Berechtigungsprofil, eine Fehlerhistorie, eine Reconciliation Queue und einen kontrollierten Abschaltpfad.

Automatisierung wird nicht als verstecktes Skripting verstanden, sondern als **versioniertes, testbares und erklärbares Produktobjekt**. Ein Workflow besteht aus Trigger, Scope, Bedingungen, Kontextanreicherung, Aktionen, menschlichen Gates, Fehlerpfaden, Evidenz, Erfolgskriterien und Rollback-Regeln. Die Plattform unterscheidet strikt zwischen:

- deterministischer Automatisierung,
- regelbasierter Empfehlung,
- KI-gestützter Assistenz,
- menschlicher Entscheidung.

Beratungen können geprüfte Workflow Blueprints erstellen und mandantenübergreifend wiederverwenden. Kunden können diese erben, konfigurieren, pausieren oder ablehnen. Keine Automatisierung darf kostenpflichtige Services buchen, Risiken akzeptieren, kritische Findings schließen, externe Systeme destruktiv verändern oder Managemententscheidungen vortäuschen, ohne die in Dokument 08, 11, 13 und 19 definierten Freigaben.

## Integrations- und Automatisierungs-Nervensystem



Prinzip: Quellen bleiben Quellen; die Plattform übersetzt Signale in belastbare ISMS-Entscheidungen.

Abbildung 1: Externe Systeme werden über Connector Gateway, Reconciliation, Graph und Workflows in belastbare Entscheidungen übersetzt.

## 3. Integrations- und Automatisierungsverfassung

### 3.1 Verbindliche Grundprinzipien

- **IA01 – Quellsysteme bleiben Quellen:** Die Plattform ersetzt SIEM, CMDB, Ticketing, Scanner, HR, Finance oder Dokumentenplattformen nicht pauschal, sondern referenziert und kontextualisiert deren relevante Informationen.
- **IA02 – Canonical First:** Externe Daten werden nicht direkt in beliebige Produktmodule geschrieben, sondern über versionierte Datenverträge in die kanonischen Objekte und Beziehungen aus Dokument 07 überführt.
- **IA03 – Herkunft bleibt erhalten:** Jedes importierte Feld kennt Quelle, externe ID, Abrufzeit, Mapping-Version, Transformationsweg, Confidence und gegebenenfalls menschliche Bestätigung.
- **IA04 – Least Privilege:** Connectoren erhalten nur die für den vereinbarten Zweck erforderlichen Rechte. Read-only ist Standard; Schreibzugriffe benötigen zusätzliche Freigabe und separate Credentials oder Scopes.
- **IA05 – Event vor Polling, aber nicht blind:** Near-Realtime-Events werden bevorzugt, wenn sie zuverlässig verfügbar sind. Ein Reconciliation- oder Polling-Fallback verhindert dauerhafte Lücken bei verlorenen Webhooks.
- **IA06 – Idempotenz:** Wiederholte Zustellung desselben Events oder Datensatzes darf keine doppelten Objekte, Tasks, Findings oder Entscheidungen erzeugen.
- **IA07 – Keine stille Überschreibung:** Konflikte zwischen Quellen, manuellen Werten und bestehenden Freigaben werden sichtbar reconciled.
- **IA08 – Menschliche Kontrolle:** Kritische oder irreversible Aktionen benötigen ein definiertes Human Gate.
- **IA09 – Erklärbarkeit:** Jede Automation zeigt Trigger, verwendete Daten, Regelversion, Entscheidungspfad, ausgeführte Aktionen und Ergebnis.
- **IA10 – Reversibilität:** Mappings, Regeln, Workflows und Schreibaktionen besitzen, soweit technisch möglich, Vorschau, Testmodus, Versionierung, Rollback oder kompensierende Aktion.
- **IA11 – Fehler sind Betriebszustände:** Rate Limits, Authentifizierungsfehler, Schemaänderungen, Timeout, unvollständige Payloads und Zielsystemausfälle werden modelliert, nicht nur geloggt.
- **IA12 – Mandantentrennung:** Connections, Credentials, Events, Staging, Dead Letters und Logs sind mandantenspezifisch isoliert.
- **IA13 – Datenminimierung:** Connectoren lesen und speichern nur Felder, die für einen dokumentierten Use Case erforderlich sind.
- **IA14 – Konfiguration vor Code:** Häufige Mappings, Regeln und Workflows sollen durch kontrollierte Konfiguration möglich sein; komplexe Erweiterungen bleiben versionierter Code.
- **IA15 – Standards vor proprietären Sonderwegen:** REST-Schnittstellen werden maschinenlesbar beschrieben; Ereignisse erhalten ein einheitliches Envelope; Identity-Provisioning orientiert sich an etablierten Standards.
- **IA16 – Operative Sichtbarkeit:** Nutzer sehen Datenfrische, Connector Health, letzte erfolgreiche Synchronisation, offene Konflikte und Auswirkungen auf Entscheidungen.
- **IA17 – Kein Automations-Theater:** Eine Automation gilt erst als wertvoll, wenn sie messbar Zeit, Fehler, Wartezeit, Risiko oder Rework reduziert.
- **IA18 – Demo ohne Produktivdaten:** Der Prototyp arbeitet mit synthetischen Connector-Payloads, Mock-Endpunkten und kontrollierten Sandboxen.

### 3.2 Was ausdrücklich vermieden wird

- direkte Punkt-zu-Punkt-Logik zwischen jedem externen System und jedem Produktmodul,

- Connectoren mit globalen Administratorrechten als Standard,
- automatisches Schließen von Risiken oder Findings nur aufgrund eines Fremdsystemstatus,
- unkontrollierte bidirektionale Synchronisation,
- Workflows ohne Owner, Version, Test und Abschaltmöglichkeit,
- versteckte KI-Entscheidungen innerhalb deterministischer Regeln,
- Polling in kurzen Intervallen ohne Rate-Limit- und Kostenkontrolle,
- Speicherung kompletter Fremdsystemdaten „für später“,
- Trigger, die sich gegenseitig in Endlosschleifen auslösen,
- ein No-Code-Designer, der sicherheitskritische Komplexität hinter bunten Kästen versteckt,
- produktive Credentials, Tokens oder Kundendaten im Repository oder in Demo-Dateien,
- Erfolgsmessung anhand der bloßen Zahl automatisierter Schritte.

## 4. Zielbild: Das Nervensystem der Plattform

Die Integrations- und Automatisierungsschicht besteht aus sieben logisch getrennten Ebenen:

- 1. External Systems:** Identität, Organisation, Cloud, CMDB, Security, Ticketing, Dokumente, Kommunikation, Finance, PSA, Kalender, Reise und weitere Quellen.
- 2. Connector Gateway:** Authentifizierung, Protokolladapter, Rate-Limit-Steuerung, Capability Discovery, sichere Aufrufe und Webhook-Empfang.
- 3. Staging & Validation:** unveränderte Rohpayloads mit begrenzter Aufbewahrung, Schema- und Qualitätsprüfung, Viren- und Formatkontrolle, Quarantäne.
- 4. Mapping & Reconciliation:** Transformation in kanonische Objekte, Matching, Dublettenprüfung, Konfliktauflösung und Confidence.
- 5. Canonical Graph & Event Backbone:** freigegebene Objektänderungen, Beziehungen, Historie, Events und Impact-Propagation.
- 6. Workflow & Automation Engine:** Trigger, Regeln, Human Gates, Aktionen, SLAs, Fehlerpfade und Nachweise.
- 7. Experience & Decisions:** Morning Mission, Kundensicht, Beraterportfolio, Aufgaben, Decision Cards, Reports und Managed-Service-Delivery.

Zwischen den Ebenen bestehen stabile Verträge. Ein Connector kennt beispielsweise Microsoft Defender oder Jira, aber nicht die Logik des Executive Dashboards. Das Decision Center kennt kanonische Risiken und Findings, aber nicht die Rohstruktur eines Herstellers. Dadurch können Connectoren ersetzt oder versioniert werden, ohne das gesamte Produkt zu destabilisieren.

## 5. Kanonische Integrationsobjekte

### 5.1 Connector Definition

Die **Connector Definition** beschreibt einen unterstützten Systemtyp und seine technischen Fähigkeiten. Sie enthält Hersteller, Produktfamilie, unterstützte Versionen, Protokolle, Authentifizierungsarten, Datenobjekte, Events, zulässige Lese- und Schreibaktionen, Rate-Limit-Muster, bekannte Einschränkungen, Teststatus und Owner.

### 5.2 Connection Instance

Eine **Connection Instance** ist die mandantenspezifische, konfigurierte Verbindung zu einem konkreten Quellsystem. Sie enthält Endpoint, Region, Tenant- oder Account-ID, Credential Reference, aktivierte Capabilities, Scope, Zeitplan, Status, Health, Datenresidenz, Owner und letzte Tests.

### 5.3 Credential Reference

Die **Credential Reference** verweist auf ein Geheimnis in einem geeigneten Secret Store. Die Plattform speichert in fachlichen Objekten niemals Klartext-Credentials. Referenzen enthalten Typ, Owner, Scopes, Ablaufdatum, letzte Rotation, Status und erlaubte Connection Instances.

### 5.4 Data Contract

Ein **Data Contract** beschreibt, welche externen Felder in welchem Format erwartet werden, welche semantische Bedeutung sie haben, welche Pflichtfelder gelten, welche Sensitivität vorliegt und auf welche kanonischen Attribute sie abgebildet werden dürfen. Der Vertrag ist versioniert und testbar.

### 5.5 Mapping Profile

Das **Mapping Profile** enthält Transformations-, Matching- und Prioritätsregeln für eine konkrete Datenquelle und einen Scope. Standardprofile können geerbt werden; kundenspezifische Abweichungen sind versioniert und begründet.

### 5.6 Sync Job

Ein **Sync Job** ist eine geplante oder ad hoc ausgeführte Datenabholung. Er kennt Modus, Cursor oder Delta Token, Start, Ende, Datensätze, Seiten, Fehler, Rate Limits, Checkpoint, Retry und Reconciliation-Ergebnis.

## 5.7 Event Subscription

Eine **Event Subscription** beschreibt abonnierte Ereignisse, Endpoint, Secret oder Zertifikat, Filter, Laufzeit, Renewal, erwartete Frequenz, letzte Zustellung, Health und Fallback-Synchronisation.

## 5.8 Event Envelope

Der **Event Envelope** vereinheitlicht externe und interne Events. Mindestattribute sind Event-ID, Typ, Quelle, Mandant, Zeitpunkt, Empfangszeit, Subject, Correlation ID, Causation ID, Schema-Version, Sensitivität, Replay-Status und Payload Reference.

## 5.9 Import Batch

Ein **Import Batch** bündelt Datei- oder API-Datensätze, Validierung, Mapping-Vorschau, Konflikte, Freigabe, Übernahme, Reconciliation und Rollback-Status. Er folgt dem in Dokument 16 definierten Importprozess.

## 5.10 Reconciliation Case

Ein **Reconciliation Case** entsteht, wenn ein Wert, Objekt oder Relationship nicht sicher übernommen werden kann. Er enthält Konflikt, Quellen, Vorschlag, Confidence, Auswirkung, Owner, Entscheidung und Historie.

## 5.11 Automation Blueprint

Ein **Automation Blueprint** ist eine wiederverwendbare, versionierte Vorlage mit Zweck, Triggern, Voraussetzungen, Regeln, Aktionen, Human Gates, Fehlerpfaden, KPIs, Testfällen und erlaubten Konfigurationspunkten.

## 5.12 Workflow Definition und Workflow Instance

Die **Workflow Definition** ist das freigegebene Design. Eine **Workflow Instance** ist eine konkrete Ausführung für einen Mandanten, Scope oder Fall. Sie enthält Regelversion, Inputs, Schritte, Status, Entscheidungen, Outputs, Evidenz, Fehler und Laufzeit.

## 5.13 Connector Health Record

Der **Connector Health Record** verdichtet Authentifizierung, Erreichbarkeit, Datenfrische, Fehlerquote, Rate-Limit-Nähe, Subscription-Status, Schemaabweichungen, Backlog und Reconciliation Queue zu einem nachvollziehbaren Zustand.

## 5.14 Dead-Letter Item

Ein **Dead-Letter Item** ist ein dauerhaft oder wiederholt fehlgeschlagenes Event oder Kommando, das nicht automatisch weiterverarbeitet wird. Es benötigt Ursache, Payload Reference, Retry-Historie, Sensitivität, Owner, Entscheidung und Abschlussnachweis.

# 6. Integrationsmuster und Auswahlregeln

| Muster                         | Geeignet für                                       | Stärken                        | Risiken und Pflichtkontrollen                                           |
|--------------------------------|----------------------------------------------------|--------------------------------|-------------------------------------------------------------------------|
| Manuelle Erfassung             | wenige kritische Entscheidungen oder fehlende APIs | kontrolliert, verständlich     | Aufwand, Aktualität; Owner und Review nötig                             |
| Dateiimport                    | Migration, Baseline, periodische Exporte           | breit verfügbar, prototypfähig | Formatfehler, Dubletten; Vorschau, Quarantäne, Reconciliation           |
| Geplante Vollsynchronisation   | kleine Datenmengen, einfache APIs                  | einfach zu betreiben           | Last, Rate Limits; Zeitfenster und Cursor                               |
| Delta-Synchronisation          | große Bestände mit Änderungsmarkern                | effizient, nachvollziehbar     | Tokenverlust; Checkpoints und Full-Rebuild-Pfad                         |
| Webhook                        | zeitnahe Ereignisse                                | geringe Latenz                 | Verlust, Duplikate, Spoofing; Signatur, Replay-Schutz, Polling-Fallback |
| Streaming                      | hohes Volumen, Security Events                     | skalierbar, near real time     | Kosten, Reihenfolge, Backpressure; Partitionierung und Retention        |
| Bidirektionale Synchronisation | wenige klar definierte Objekte                     | reduziert Doppelpflege         | Konflikte, Schleifen; System-of-Record-Regel und Idempotenz             |

Die Wahl folgt dem Use Case, nicht dem Wunsch nach maximaler Echtzeit. Für Management- und Reifegradinformationen genügt häufig tägliche oder stündliche Aktualisierung. Kritische Incidents oder Identity-Änderungen können eventgetrieben verarbeitet werden. Der UI zeigt die tatsächliche Datenfrische, statt jede Information als „live“ darzustellen.



## 7. Connector-Lifecycle

### 7.1 Discover und Qualify

Vor Einrichtung werden Zweck, Quellsystem, Datenobjekte, erwartete Frequenz, Volumen, Region, Verantwortlicher, API-Lizenz, Authentifizierung, Berechtigungen, Schreibbedarf und Exit-Anforderung geklärt. Eine Connection wird nicht eingerichtet, nur weil technisch eine API existiert.

### 7.2 Configure und Authorize

Der Administrator wählt Capability und Scope, erzeugt oder referenziert Credentials, prüft Scopes und Datenregion und führt einen Connection Test aus. Schreibrechte werden separat aktiviert und dokumentiert.

### 7.3 Map und Preview

Ein Sample wird eingelesen, gegen den Data Contract validiert und in einer Mapping-Vorschau dargestellt. Nutzer sehen externe Felder, Zielattribute, Transformationen, Konflikte, verworfene Felder und erwartete Graph-Änderungen.

### 7.4 Validate und Approve

Tests prüfen Datenqualität, Volumen, Performance, Berechtigungen, negative Fälle und Mandantentrennung. Ein fachlicher Owner bestätigt Semantik; ein technischer Owner bestätigt Betrieb; bei sensiblen Daten erfolgt Security- oder Privacy-Freigabe.

### 7.5 Activate und Observe

Nach Aktivierung werden Health, Frische, Fehler, Eventlag, Reconciliation und Auswirkungen überwacht. Die Connection kann read-only, write-enabled, degraded, paused, quarantined oder retired sein.

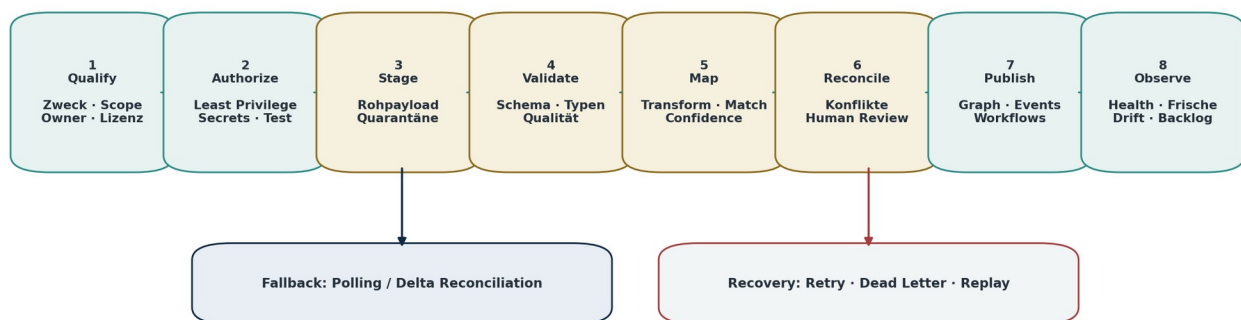
### 7.6 Change und Upgrade

API-Versionen, Schemaänderungen, neue Scopes oder Herstellerupdates erzeugen einen Impact Check. Mapping und Data Contract werden versioniert; alte Versionen bleiben für Replay und Nachvollziehbarkeit verfügbar.

### 7.7 Pause, Revoke und Retire

Pausieren stoppt neue Verarbeitung, ohne Historie zu löschen. Revoke entzieht Credentials und Subscriptions. Retire archiviert Konfiguration, führt letzte Reconciliation aus, löscht oder minimiert Staging-Daten nach Regel und dokumentiert offene Abhängigkeiten.

#### Connector-Lifecycle mit kontrollierter Datenübernahme



Jeder Schritt ist versioniert, prüfbar und checkpointfähig. Keine stille Übernahme in produktive Objekte.

Abbildung 2: Der Connector-Lifecycle trennt Qualifizierung, Autorisierung, Staging, Validierung, Mapping, Reconciliation, Veröffentlichung und Betrieb.

## 8. Authentifizierung, Autorisierung und Secrets

### 8.1 Unterstützte Muster

Die Plattform soll mindestens OAuth 2.0 / OpenID Connect, Client Credentials, zertifikatsbasierte Authentifizierung, API Keys in Secret Stores, signierte Webhooks, Service Accounts und bei Identity-Provisioning SCIM-kompatible Muster unterstützen. Veraltete oder risikoreiche Verfahren werden nur für bestehende Systeme und mit expliziter Ausnahme zugelassen.

### 8.2 Sicherheitsanforderungen

- Authorization Code mit PKCE für interaktive Benutzerverbindungen,

- Client Credentials nur für klar abgegrenzte Maschinenidentitäten,
- minimale Scopes und getrennte Read-/Write-Credentials,
- Token nicht in Logs, Fehlermeldungen, URLs oder Repositories,
- kurze Laufzeiten, Rotation und Revocation,
- mTLS oder private Netzpfade für besonders schützenswerte Integrationen,
- Webhook-Signaturprüfung, Timestamp-Prüfung und Replay-Schutz,
- Credential Health und Ablaufwarnungen,
- JIT-Aktivierung privilegierter Schreibaktionen, soweit unterstützt,
- nachvollziehbare Zustimmung und Owner je Connection.

Die genaue technische Implementierung folgt Dokument 18 und 19. Als Sicherheitsbasis für OAuth-orientierte Integrationen ist die aktuelle OAuth 2.0 Security Best Current Practice zu berücksichtigen.

### 8.3 Credential-Lifecycle

Credentials besitzen Owner, Zweck, Scope, Erstellungsdatum, Ablauf, Rotation, letzte Nutzung und Widerrufsstatus. Ein Owner-Wechsel oder Kunden-Exit löst Review und gegebenenfalls Rotation aus. Nicht genutzte Credentials werden deaktiviert.

## 9. Data Contracts und kanonische Semantik

Ein Connector darf externe Werte nicht nur syntaktisch, sondern muss sie semantisch übersetzen. Beispielsweise ist „critical“ in einem Scanner nicht automatisch identisch mit einem kritischen Business-Risiko. Der Data Contract trennt deshalb:

- externen Rohwert,
- normalisierte technische Bedeutung,
- kanonisches Plattformattribut,
- fachliche Interpretation,
- zulässige Verwendung,
- Confidence und Quelle.

Data Contracts werden als versionierte, maschinenlesbare Artefakte gepflegt. Für HTTP-APIs ist eine OpenAPI-Beschreibung anzustreben; eventbasierte Schnittstellen werden mit einer geeigneten asynchronen Spezifikation dokumentiert. Event-Payloads erhalten ein einheitliches Envelope, das sich an CloudEvents-Prinzipien orientiert. Dies sind Architekturentscheidungen, keine Verpflichtung, jede Hersteller-API unverändert in einem bestimmten Standard abzubilden.

### 9.1 Feldklassen

| Feldklasse     | Beispiel                       | Behandlung                                                       |
|----------------|--------------------------------|------------------------------------------------------------------|
| Identifizier   | externe Asset-ID               | stabil speichern, Namespace und Quelle erhalten                  |
| Business Key   | Hostname, E-Mail, Ticketnummer | normalisieren, aber nicht allein als globale Identität verwenden |
| Status         | Open, Closed, Resolved         | auf kanonischen Status mappen und Rohwert erhalten               |
| Severity       | Critical, High, P1             | technische Skala getrennt vom Business Impact speichern          |
| Timestamp      | created, updated, observed     | Zeitzone und Semantik dokumentieren                              |
| Relationship   | finding affects asset          | als versionierte Graph-Beziehung mit Provenance anlegen          |
| Evidence       | Scanbericht, Ticketlink        | referenzieren oder kontrolliert übernehmen                       |
| Sensitive Data | Person, Secret, Loginhalt      | minimieren, klassifizieren, maskieren oder verwerfen             |

## 10. Mapping, Transformation und Normalisierung

### 10.1 Transformationsschritte

1. Transport und Decoding,
2. Strukturvalidierung,
3. Typ- und Wertprüfung,
4. Normalisierung von Zeit, Region, Status und Severity,
5. Feld- und Objektmapping,
6. Identity Matching,
7. Relationship Mapping,
8. Business-Regelanreicherung,



- 9. Confidence-Berechnung,
- 10. Vorschau und Reconciliation,
- 11. kontrollierte Veröffentlichung.

## 10.2 Mapping-Regeln

Mapping-Regeln dürfen Werte umbenennen, kombinieren, filtern, konvertieren oder ableiten. Sie dürfen keine nicht belegten Fakten erzeugen. Jede abgeleitete Information erhält eine Rule ID und Methodik. Kundenspezifische Mappings erben ein Standardprofil und dokumentieren Abweichungen.

## 10.3 Umgang mit fehlenden und ungültigen Daten

Pflichtfelder führen nicht automatisch zum Abbruch des gesamten Batches. Datensätze können accepted, accepted with warning, quarantined oder rejected sein. Kritische Identifier- oder Scopefehler blockieren Veröffentlichung. Fehlende Zusatzfelder reduzieren Confidence und erzeugen bei Relevanz ein Data Improvement Item.

# 11. Identity Resolution, Dubletten und Reconciliation

## 11.1 Matching-Hierarchie

- verifizierte externe ID im gleichen Namespace,
- vorher bestätigte Cross-System-Verknüpfung,
- eindeutiger Business Key innerhalb des Scopes,
- gewichtetes Multi-Attribut-Matching,
- manueller Reconciliation Case.

Fuzzy Matching darf Vorschläge erzeugen, aber keine kritischen Objekte automatisch zusammenführen. Ein Merge ist versioniert und reversibel; ein Split stellt vorherige Objekte und Beziehungen wieder her.

## 11.2 Source-of-Record-Regel

Für jedes Attribut kann eine Prioritätsregel gelten: autoritatives System, manuelle freigegebene Eingabe, neueste Beobachtung oder kombinierte Berechnung. Ein manuell bestätigter Scope-Ausschluss darf beispielsweise nicht durch einen Scannerimport still aufgehoben werden.

## 11.3 Konfliktarten

- zwei Quellen melden unterschiedliche Owner,
- Quellsystem löscht ein Objekt, das weiterhin Beziehungen besitzt,
- Ticketstatus „geschlossen“, aber Evidence fehlt,
- Asset-ID wird wiederverwendet,
- Person verlässt das Unternehmen, bleibt aber Control Owner,
- Severity sinkt, Business Impact bleibt hoch,
- externe Quelle ändert Schema oder Bedeutung eines Feldes.

Jeder Konflikt zeigt Auswirkung, empfohlene Entscheidung, Confidence und betroffene Workflows.

# 12. Synchronisation und Checkpoints

## 12.1 Full Sync

Eine Vollsynchronisation wird für Erstaufbau, Rekonstruktion oder kontrollierten Repair verwendet. Sie läuft paginiert, checkpointfähig und mit Ressourcengrenzen. Ein Abbruch setzt am letzten sicheren Checkpoint fort.

## 12.2 Delta Sync

Wenn ein Quellsystem Delta- oder Cursor-Mechanismen anbietet, speichert die Plattform den letzten bestätigten Token erst nach erfolgreicher Veröffentlichung. Tokenverlust oder Ablauf löst einen kontrollierten Full-Rebuild oder definierten Zeitraumsscan aus.

## 12.3 Webhooks

Webhook-Verarbeitung umfasst Endpoint-Validierung, Signatur, Zeitfenster, Replay-Schutz, schnelle Annahme, asynchrone Verarbeitung und erneute Abholung des vollständigen Objekts, wenn die Benachrichtigung nur eine Referenz enthält. Subscription-Renewal ist ein eigener Health-Check.

## 12.4 Dual-Path-Reconciliation

Für kritische Events gilt ein Zwei-Wege-Modell:

- primärer Weg über Webhook oder Stream,
- sekundärer geplanter Abgleich über API oder Delta Sync.

Damit werden verlorene Zustellungen, temporäre Ausfälle und erschöpfte Retries erkannt. Der Abgleich darf keine Doppelaktionen auslösen, weil Event ID, externe Objektversion und Idempotency Key geprüft werden.

## 13. Event Backbone

### 13.1 Ereignistypen

- External Object Created / Updated / Deleted,
- Identity Changed,
- Asset Discovered / Retired,
- Finding Opened / Changed / Resolved,
- Incident Created / Escalated / Closed,
- Ticket Changed,
- Evidence Added / Expired,
- Scope Changed,
- Control Test Failed,
- Threat Relevance Changed,
- SLA At Risk,
- Connector Degraded,
- Workflow Failed,
- Decision Approved / Rejected,
- Service Activated / Paused / Ended.

### 13.2 Correlation und Causation

Eine Correlation ID verbindet alle Schritte eines fachlichen Falls. Eine Causation ID zeigt, welches Event einen Folgeschritt ausgelöst hat. Dadurch kann die Plattform erklären, warum ein Task, Risiko-Update oder Report entstanden ist und Schleifen erkennen.

### 13.3 Zustellung und Verarbeitung

Die interne Zielsemantik ist mindestens once delivery mit idempotenter Verarbeitung. Exactly-once wird nicht als pauschales Versprechen verwendet. Consumer speichern Verarbeitungszustand, erkennen Duplikate und können Events kontrolliert replaysen.

### 13.4 Ordering und Backpressure

Reihenfolge wird nur dort garantiert, wo sie fachlich nötig ist, beispielsweise pro externem Objekt oder Workflow Instance. Bei Lastspitzen werden Events gepuffert, priorisiert und gegebenenfalls gedrosselt. Managementansichten zeigen Eventlag und Datenfrische.

## 14. Priorisierter Connector-Katalog

| Priorität | Connector-Familie                   | Nutzen im Zielprodukt                        | Prototyp-Tiefe                                    |
|-----------|-------------------------------------|----------------------------------------------|---------------------------------------------------|
| P0        | Identity / Entra / SCIM             | Nutzer, Gruppen, Rollen, Joiner-Mover-Leaver | echter oder Mock-Connector mit Delta und Events   |
| P0        | Ticketing / Jira                    | Tasks, Findings, Status, Kommentare, Links   | echter Sandbox-Connector oder vollständiger Mock  |
| P0        | Microsoft Defender XDR              | Incidents, Alerts, betroffene Entities       | offizielles API-Muster mit synthetischen Payloads |
| P0        | Dateiimport CSV/XLSX/JSON           | universeller Einstieg und Migration          | vollständig funktionsfähig                        |
| P0        | Webhook- und Generic REST Connector | Erweiterbarkeit und Demo                     | vollständig funktionsfähig gegen Mock API         |
| P1        | ServiceNow / CMDB / ITSM            | CIs, Incidents, Changes, Tasks               | Mapping- und Sandbox-Simulation                   |
| P1        | Cloud Security / AWS Security Hub   | Findings, Ressourcen, Controls               | synthetischer Event- und API-Flow                 |
| P1        | Dokumente / SharePoint / Drive      | Policies, Evidence, Reviewdaten              | Metadaten- und Linkintegration                    |
| P1        | Kalender / Teams                    | Termine, Reviews, Auditbesuche               | Demo mit synthetischem Kalender                   |
| P1        | Vulnerability Management            | Findings, Assets, Remediation                | herstellerneutraler Mock-Connector                |
| P2        | SIEM / SOAR / Sentinel / Splunk     | Signale, Incidents, Response                 | abstrakte Capability und spätere Adapter          |
| P2        | PSA / Finance / Travel              | Aufwand, Kosten, Reisen, Profitabilität      | synthetische Daten und Import                     |

| Priorität | Connector-Familie          | Nutzen im Zielprodukt                     | Prototyp-Tiefe                             |
|-----------|----------------------------|-------------------------------------------|--------------------------------------------|
| P2        | HRIS                       | Organisation, Rollen, Skills, Abwesenheit | SCIM/Import-orientiert, Datenschutzprüfung |
| P3        | Branchen- und Spezialtools | individuelle Ökosysteme                   | Connector SDK / Partner-Modell             |

Die Priorisierung beschreibt die Produktentwicklung, nicht eine Aussage über kommerzielle Partnerschaften oder bereits implementierte Herstellerintegration.

## 15. Identity- und Organisationsintegrationen

Identity-Systeme liefern Nutzer, Gruppen, Rollen, Organisationseinheiten und Lifecycle-Änderungen. Die Plattform übernimmt nur für Governance und Verantwortlichkeit erforderliche Attribute. Passwörter, Authentifizierungsgeheimnisse und unnötige Profildaten werden nicht importiert.

### 15.1 Kern-Use-Cases

- Control Owner verlässt das Unternehmen,
- Nutzer wechselt Organisationseinheit,
- privilegierte Gruppe verändert sich,
- neue Führungskraft benötigt Decision-Aufgaben,
- Auditorzugriff läuft aus,
- Vertretung und Backup Owner fehlen,
- Rolle wird deaktiviert, offene Freigaben müssen neu zugewiesen werden.

### 15.2 SCIM und Delta-Muster

SCIM ist für standardisierte Provisionierung von Usern und Gruppen geeignet; herstellerspezifische APIs können darüber hinaus Delta- und Eventmechanismen anbieten. Die Plattform muss die Quelle und den Zweck jedes Attributs erhalten. Identity-Änderungen erzeugen keine automatische fachliche Verantwortung, sondern einen Review- oder Reassignment-Workflow.

## 16. Asset-, Cloud- und CMDB-Integrationen

Assetquellen liefern technische und organisatorische Objekte, aber keine vollständige Business-Kritikalität. Der Connector mappt Ressourcen, Services, Tags, Eigentümer, Standorte und Abhängigkeiten in den Graph. Kritikalität, Scope und Schutzbedarf bleiben fachlich freizugebende Plattformobjekte.

### 16.1 CMDB-Use-Cases

- neue Configuration Item im Scope,
- kritischer Service verliert Owner,
- Dependency ändert sich,
- Asset wird retired, offene Findings bleiben,
- CMDB und Cloud Inventory widersprechen sich,
- Change betrifft einen kontrollrelevanten Service.

### 16.2 Cloud-Use-Cases

- neue Cloud-Ressource ohne verpflichtende Tags,
- Security Finding betrifft geschäftskritischen Prozess,
- Account oder Subscription wird neu verbunden,
- Region verletzt Datenresidenzvorgabe,
- öffentlich erreichbarer Dienst verändert Risiko,
- Control Evidence kann automatisiert erneuert werden.

## 17. Security-, Threat- und Vulnerability-Integrationen

Security-Quellen liefern technische Beobachtungen. Die Plattform übersetzt sie in Kontext, aber übernimmt Severity nicht unkritisch als Business-Risiko.

### 17.1 Incident-Flow

Ein neuer Incident wird mit betroffenen Entities importiert, gegen Assets und Geschäftsprozesse gemappt, nach Scope und Kritikalität bewertet und als Signal an Risiko-, Control- und Decision-Logik übergeben. Die Plattform kann Tasks, Review, Evidenzanforderung oder Managementinformation auslösen. Klassifikation oder Schließung im Quellsystem bleibt nachvollziehbar; ein ISMS-Risiko wird nicht automatisch geschlossen.

## 17.2 Vulnerability-Flow

Findings werden dedupliziert, mit Asset, Exposure, Exploitability, Business-Kritikalität und bestehenden Controls verbunden. Eine technische Critical-Severity auf einem isolierten Testsystem kann niedriger priorisiert werden als eine High-Severity auf einem zentralen Identitätssystem. Die Begründung bleibt sichtbar.

## 17.3 Threat-Intelligence-Flow

Neue Threat-Signale werden gegen Technologie, Branche, Geografie, Assets, Lieferanten und Controls gemappt. Relevanzänderungen können Route, Priorität und Morning Mission beeinflussen, aber keine kostenpflichtige Maßnahme automatisch auslösen.

# 18. Ticketing- und Work-Management-Integrationen

Ticketing-Systeme können operatives System of Record für Tasks bleiben. Die Plattform hält fachlichen Kontext, Beziehung zu Risiko, Control, Service und Entscheidung sowie synchronisierten Status.

## 18.1 Synchronisationsmodell

- Plattform erzeugt optional Ticket mit stabilem External Link,
- Ticketstatus und ausgewählte Felder werden zurückgelesen,
- Konfliktregeln bestimmen, welches System Owner, Due Date oder Status führen darf,
- Kommentare werden nicht ungefiltert dupliziert,
- vertrauliche Inhalte bleiben im jeweils zulässigen System,
- „Done“ im Ticket bedeutet nicht automatisch „wirksam“ im ISMS.

## 18.2 Jira und ServiceNow als Referenzmuster

Jira Cloud stellt REST- und Webhook-Funktionen für Issues bereit. ServiceNow bietet REST-Zugriff, Table APIs, Import Sets und kundenspezifische Scripted REST APIs. Das Produkt nutzt diese Fähigkeiten nur über versionierte Connectoren und unterstützt alternative Systeme über dieselben kanonischen Work-Item-Verträge.

# 19. Dokument-, Evidence- und Collaboration-Integrationen

Dokumentensysteme bleiben Speicherort für freigegebene Policies, Reports oder Nachweise, wenn dies kundenseitig gewünscht ist. Die Plattform speichert Link, Version, Hash, Owner, Klassifikation, Reviewdatum und fachlichen Zusammenhang. Dateien werden nur übernommen, wenn Offline-Verfügbarkeit, Nachweisstabilität oder sichere Reportgenerierung dies erfordern.

## 19.1 Evidence Watch

- Dokument geändert oder gelöscht,
- Reviewdatum überschritten,
- Evidence Link nicht erreichbar,
- Hash oder Version weicht ab,
- Control Test benötigt neue Evidence,
- Zugriff für Auditor fehlt,
- Dokument ist vorhanden, aber nicht für den geforderten Zeitraum geeignet.

## 19.2 Kommunikation

Teams, Slack oder E-Mail sind Benachrichtigungskanäle, nicht die zentrale Wahrheit. Entscheidungen und Freigaben müssen in der Plattform oder über einen gesicherten Deep Link mit nachvollziehbarer Rückmeldung erfolgen.

# 20. Kalender-, Reise-, PSA- und Finance-Integrationen

Diese Integrationen unterstützen Dokument 15 und dürfen nicht zu einem vollständigen ERP-Ersatz wachsen.

## 20.1 Kalender

- Audit- und Reviewtermine,
- Verfügbarkeit und Zeitzone,
- Fokuszeit und Reiseblock,
- Konflikte und fehlende Teilnehmer,
- Erinnerungen und Handover.

## 20.2 Reise

- Vor-Ort-Erfordernis,
- Reisezeit und Puffer,
- Standortcluster,
- erwartete Kosten,
- Stornierung und Ersatz,
- Visit Pack und Nachbereitung.

## 20.3 PSA und Finance

- geplante und tatsächliche Stunden,
- Cost to Serve,
- Servicebudget und Retainer,
- freigegebene Zusatzleistung,
- Reisekosten,
- Profitabilitäts- und Value-Ledger-Signale.

Finanzdaten werden minimiert und nur für definierte Portfolio- und Serviceentscheidungen genutzt.

## 21. Generic REST Connector und Connector SDK

Der **Generic REST Connector** erlaubt kontrollierte Integration nicht priorisierter Systeme. Er unterstützt:

- OpenAPI-Import oder manuelle Endpoint-Definition,
- OAuth, API Key, mTLS und Secret References,
- Pagination, Filter und Cursor,
- Request- und Response-Mapping,
- Testaufrufe mit Maskierung,
- Rate-Limit-Regeln,
- Webhook-Empfang,
- Retry und Dead Letter,
- synthetische Samples,
- Read-only als Default.

Ein späteres **Connector SDK** stellt Templates, Contract Tests, Mock Server, Security Linting, Versionierung, Packaging und Marketplace-Freigabe bereit. Eigene Connectoren dürfen keine direkte Datenbank- oder Modulkopplung erhalten.

## 22. Dateiimport und Export als kontrollierter Fallback

CSV, XLSX, JSON und gegebenenfalls XML bleiben strategisch wichtig, weil nicht jedes Kundensystem eine geeignete API oder Lizenz bereitstellt.

### 22.1 Importanforderungen

- Upload mit Malware- und Formatprüfung,
- Datenklassifikation und Größenlimit,
- Spalten- und Typinferenz nur als Vorschlag,
- Mapping Assistant und gespeicherte Profile,
- Sample-Vorschau,
- Fehlerbericht pro Zeile,
- partielle Annahme mit Quarantäne,
- Reconciliation und Freigabe,
- Batch-ID und Rollback-Fenster,
- vollständige Herkunft.

### 22.2 Exportanforderungen

- filterbare kanonische Daten,
- verständliche Feldbeschreibungen,
- maschinenlesbare IDs und Beziehungen,
- Datenschutz- und Scope-Prüfung,
- signierter oder gehashter Snapshot bei Bedarf,
- Exit Package aus Dokument 16,
- kein Export von Secrets oder unzulässigen Cross-Tenant-Benchmarks.

## 23. Workflow-Designer

Der Workflow-Designer ist die kontrollierte Oberfläche zum Erstellen, Prüfen und Aktivieren von Automatisierung. Er bietet eine visuelle Ansicht und eine präzise Definition. Die visuelle Ansicht darf die zugrunde liegende Logik nicht verbergen.

### 23.1 Workflow-Bausteine

- Trigger,
- Scope Selector,
- Context Loader,
- Condition,
- Branch,
- Wait / Schedule,
- Task Creation,
- Evidence Request,

- Notification,
- Decision Card,
- External Command,
- Data Update,
- Report Generation,
- Human Approval,
- Review Gate,
- Sub-Workflow,
- Compensation / Rollback,
- End State.

## 23.2 Designer-Modi

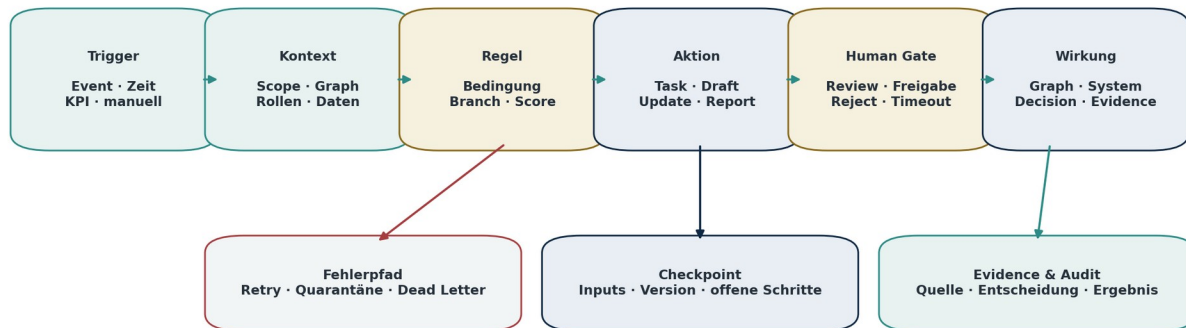
- **Guided Mode:** sichere Vorlagen mit wenigen Parametern,
- **Expert Mode:** Bedingungen, Mappings, Variablen und Fehlerpfade,
- **Read-only Explain Mode:** vollständige Erklärung für Reviewer und Auditoren,
- **Test Mode:** synthetische Payloads und Simulation ohne Wirkung,
- **Diff Mode:** Änderungen zwischen Versionen und erwartete Auswirkungen.

## 23.3 Veröffentlichungsprozess

Draft → Validated → Tested → Reviewed → Approved → Active → Deprecated → Retired.

Jede Aktivierung benötigt Owner, Scope, Testnachweis, Berechtigungsprüfung und Rollback-Plan. Kritische Blueprints benötigen unabhängiges Review.

### Workflow-Ausführungsmodell



Deterministische Automation, Empfehlung, KI-Assistenz und menschliche Entscheidung bleiben getrennt.

Abbildung 3: Workflows verbinden Trigger, Kontext, Regeln, Aktionen, Human Gates, Wirkung, Recovery und Auditnachweis.

# 24. Trigger, Bedingungen und Regeln

## 24.1 Triggerfamilien

- Event aus externer Quelle,
- Änderung eines kanonischen Objekts,
- Zeitplan oder Frist,
- KPI- oder Schwellenwert,
- fehlende Evidence,
- Statuswechsel,
- Decision Outcome,
- manueller Start,
- API-Aufruf,
- Lifecycle Event,
- Connector Health Event.

## 24.2 Regelanforderungen

Regeln sind deterministisch, versioniert und mit verständlicher Sprache beschreibbar. Jede Regel kennt Inputs, Nullverhalten, Datentypen, Scope, Zeitzone, Priorität und Konfliktverhalten. Scheingenauigkeit wird vermieden; Unsicherheit kann als Bedingung oder Human Gate verwendet werden.



## 24.3 Beispiel

**Wenn** ein High- oder Critical-Finding auf einem Asset im freigegebenen Scope eingeht, **und** das Asset einen kritischen Geschäftsprozess unterstützt, **und** kein aktives Duplikat existiert, **dann** erstelle einen Review Case, ermittle betroffene Controls, aktualisiere die Morning Mission und fordere einen Owner zur Bestätigung auf. **Nicht automatisch:** Risiko akzeptieren, Service buchen oder Finding im Scanner schließen.

## 25. Aktionen und externe Schreibzugriffe

Aktionen werden nach Risikoklasse geordnet:

| Klasse                         | Beispiele                                            | Standardfreigabe                                     |
|--------------------------------|------------------------------------------------------|------------------------------------------------------|
| A – intern und reversibel      | Tag, Notification, Draft Task                        | automatisch nach Test                                |
| B – interne fachliche Änderung | Due Date, Owner-Vorschlag, KPI-Neuberechnung         | regelbasiert, teils Review                           |
| C – externe reversible Aktion  | Ticket erstellen, Kommentar schreiben                | freigegebene Connection und Scope                    |
| D – externe kritische Änderung | Incidentstatus ändern, Asset deaktivieren            | Human Gate und Vier-Augen-Prinzip                    |
| E – Management / kommerziell   | Risiko akzeptieren, Budget freigeben, Service buchen | ausschließlich autorisierte menschliche Entscheidung |

Schreibaktionen verwenden Idempotency Keys und speichern externe Response, Status und Link. Fehlgeschlagene Aktionen werden nicht unkontrolliert wiederholt, wenn eine doppelte Wirkung möglich ist.

## 26. Human Gates und Entscheidungsrechte

Human Gates sind keine pauschalen Bestätigungsdialoge, sondern folgen Rolle, Risikoklasse, Scope und Wirkung.

### 26.1 Gate-Arten

- Owner Confirmation,
- fachliches Review,
- Security Approval,
- Privacy Approval,
- Management Decision,
- Customer Approval,
- Provider Quality Gate,
- Four-Eyes Approval,
- Emergency Override mit nachträglichem Review.

### 26.2 Gate-Inhalt

Ein Gate zeigt Auslöser, Datenbasis, Empfehlung, Alternativen, Wirkung, Confidence, Kosten, externe Aktion, Rollback und Frist. Ein Nutzer darf nicht nur „Approve“ sehen, ohne zu verstehen, was freigegeben wird.

## 27. Workflow-Bibliothek

### 27.1 Verbindliche Start-Blueprints

1. Joiner-Mover-Leaver für Control Owner,
2. Critical Finding Review,
3. Evidence Expiry Renewal,
4. Audit 90/60/30-Tage-Vorbereitung,
5. Policy Review Cycle,
6. Supplier Risk Escalation,
7. Incident-to-Risk Impact Review,
8. Scope Change Assessment,
9. Management Review Preparation,
10. Overdue Measure Escalation,
11. Connector Degradation Response,
12. Service SLA at Risk,
13. Onboarding Data Improvement,
14. Customer Lifecycle Review,
15. Exit and Credential Revocation.

## 27.2 Blueprint-Vererbung

Ein globaler Blueprint kann durch Beratungspraxis, Branche, Framework, Service Offer und Kunde schrittweise spezialisiert werden. Geerbte Pflichtschritte, Human Gates und Security Controls dürfen nicht still entfernt werden. Abweichungen werden als Overlay dokumentiert.

# 28. Managed-Service-Automatisierung

Automatisierung ist ein zentraler Skalierungshebel für Managed Services. Sie reduziert jedoch nicht pauschal Beraterarbeit, sondern verschiebt Aufwand von repetitiver Ausführung zu Review, Ausnahmebehandlung und wertschöpfender Entscheidung.

## 28.1 Provider-Perspektive

- Blueprints über Mandanten verteilen,
- Konfigurationsabweichungen vergleichen,
- Health und Backlog portfolioübergreifend sehen,
- fehlgeschlagene Workflows bündeln,
- gemeinsame Ursachen erkennen,
- Rollout gestaffelt aktivieren,
- Wirkung und Zeitersparnis messen,
- Automation Debt sichtbar machen.

## 28.2 Kundenschutz

Mandantenübergreifende Lern- oder Vergleichsdaten sind anonymisiert und aggregiert. Ein Blueprint-Update wird nicht ungeprüft auf alle Kunden ausgerollt. Kunden sehen Version, Änderung, erwartete Wirkung und können bei nicht verpflichtenden Updates aufschieben.

# 29. Workflow-Ausführung, Checkpoints und Wiederaufnahme

Jede Workflow Instance speichert nach jedem fachlich sinnvollen Schritt einen Checkpoint. Ein Checkpoint enthält Inputs, Rule Version, abgeschlossene Aktionen, externe IDs, offene Gates, Fehler, nächste Schritte und kompensierende Möglichkeiten. Dadurch kann die Ausführung nach Deployment, Worker-Ausfall oder Timeout fortgesetzt werden.

Langlaufende Workflows dürfen nicht an eine einzelne Server-Session oder einen Chat gebunden sein. Wartezeiten von Tagen oder Wochen werden als persistente Zustände modelliert. Das technische Laufzeitmodell wird in Dokument 18 festgelegt.

# 30. Fehlerbehandlung und Recovery

## 30.1 Fehlerklassen

- Authentication / Authorization,
- Network / Timeout,
- Rate Limit,
- Invalid Payload,
- Schema Drift,
- Mapping Error,
- Duplicate / Conflict,
- External Business Rule,
- External System Degraded,
- Internal Processing,
- Human Gate Timeout,
- Irreversible Partial Success.

## 30.2 Retry-Politik

Nur transiente Fehler werden automatisch mit Backoff und Jitter wiederholt. Validierungs-, Berechtigungs- oder Business-Regelfehler benötigen Korrektur. Für externe Aktionen muss vor Retry geprüft werden, ob die erste Ausführung bereits erfolgreich war.

## 30.3 Dead Letter und Replay

Nach ausgeschöpften Retries entsteht ein Dead-Letter Item. Ein berechtigter Operator kann Payload prüfen, maskierte Diagnose sehen, Mapping korrigieren und kontrolliert replays. Replay verwendet ursprüngliche Event-ID und neue Attempt-ID.

## 30.4 Compensation

Wenn ein mehrstufiger Workflow teilweise erfolgreich war, führt die Plattform keine pauschale Datenbank-Rollback-Fiktion aus. Sie nutzt definierte kompensierende Aktionen: Ticket schließen, Draft zurückziehen, Assignment entfernen oder menschliche Korrektur anfordern.

## 31. Connector Health, Observability und Operations

### 31.1 Health-Dimensionen

- Authentication,
- Reachability,
- Subscription,
- Data Freshness,
- Throughput,
- Error Rate,
- Rate Limit Headroom,
- Schema Compatibility,
- Reconciliation Backlog,
- Dead Letters,
- Processing Lag,
- Credential Expiry.

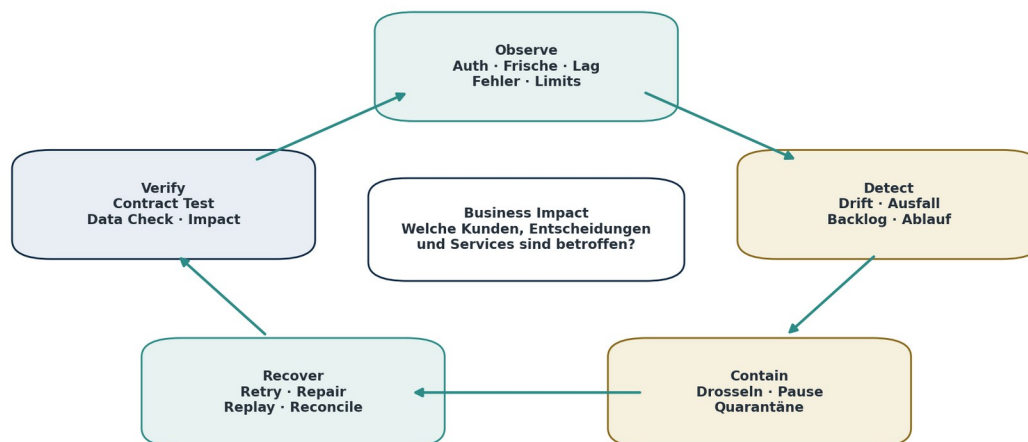
### 31.2 Zustände

Healthy, Warning, Degraded, Failed, Quarantined, Paused, Retired.

### 31.3 Operations Center

Betreiber sehen Connections nach Mandant, Service, Risiko und Auswirkung. Eine ausgefallene Identity-Synchronisation wird höher priorisiert, wenn dadurch Owner- und Zugriffsentscheidungen unzuverlässig werden. Der Status zeigt nicht nur technische Fehler, sondern betroffene Produktfunktionen und Kundenentscheidungen.

#### Connector Health & Recovery Loop



Health ist nicht nur technische Verfügbarkeit: Entscheidend ist die Auswirkung auf Datenvertrauen und Delivery.

Abbildung 4: Connector Health wird als geschlossener Beobachtungs-, Erkennungs-, Eindämmungs-, Recovery- und Verifikationskreislauf betrieben.

## 32. Rate Limits, Pagination und Kostenkontrolle

Jeder Connector implementiert:

- konfigurierbare Page Size,
- Cursor- oder Link-Following,
- adaptive Parallelität,
- Rate-Limit-Header-Auswertung,
- Backoff und Retry-After,
- Quoten pro Mandant und Connection,
- Priorisierung kritischer Events,
- Kosten- und Volumenmessung,
- Schutz vor unbounded full sync,
- Abbruch und Wiederaufnahme.

Die Plattform zeigt, wenn Daten wegen Limits verzögert sind. Sie darf Frische nicht vortäuschen. API-Kosten, Lizenzrestriktionen und zulässige Abfragevolumina werden in der Connector Definition als Betriebsannahme dokumentiert.

## 33. Schema Evolution, API-Versionierung und Deprecation

### 33.1 Versionierungsregeln

- Connector Definition und Data Contract besitzen SemVer oder gleichwertige Versionierung.
- Breaking Changes benötigen neue Major-Version und Migration.
- Mapping Profiles referenzieren eine feste Contract-Version.
- Events enthalten Schema-Version.
- Alte Payloads bleiben innerhalb definierter Retention replayfähig.
- Deprecation besitzt Datum, Nachfolger, betroffene Connections und Migrationsstatus.

### 33.2 Schema Drift Detection

Unbekannte Felder allein sind kein Fehler. Fehlende Pflichtfelder, Typänderungen, geänderte Enums oder Semantikänderungen können Connection auf Warning oder Quarantined setzen. Sample-Payloads und Contract Tests erkennen Drift vor produktiver Übernahme.

## 34. Sicherheits-, Datenschutz- und Mandantenanforderungen

Dieses Dokument legt Mindestanforderungen fest; Dokument 19 konkretisiert sie:

- mandantenspezifische Isolation von Credentials, Staging, Logs und Events,
- Verschlüsselung in Transit und at Rest,
- Datenklassifikation vor Speicherung,
- Maskierung sensibler Payloads in UI und Logs,
- begrenzte Rohdatenaufbewahrung,
- nachvollziehbare Datenflüsse und Subprozessoren,
- Rechte auf Connection-, Objekt-, Feld- und Aktionsniveau,
- keine Cross-Tenant-Payloads in globalen Supportansichten,
- Secret Scanning und Credential Rotation,
- sichere Webhook-Endpunkte und Egress-Kontrolle,
- Audit Trail für Konfiguration, Mapping, Aktivierung und externe Schreibaktion,
- Lösch-, Export- und Legal-Hold-Regeln,
- Notfallabschaltung pro Connector und global.

## 35. Teststrategie für Connectoren und Workflows

### 35.1 Connector Tests

- Contract Test gegen dokumentierte API,
- Authentication- und Scope-Test,
- Pagination und Delta,
- Rate-Limit- und Retry-Test,
- Webhook-Signatur und Replay,
- Schema Drift,
- große Datenmenge,
- Dubletten und Löschung,
- Timeout und partieller Ausfall,
- Mandantentrennung,
- Credential Rotation,
- Exit und Revocation.

### 35.2 Workflow Tests

- Happy Path,
- Null- und Grenzwerte,
- alternative Branches,
- Human Gate approve/reject/timeout,
- doppelte Events,
- verspätete Events,
- externer Fehler,
- Retry und Compensation,
- Versionswechsel,
- Pause und Resume,
- Rechteverletzung,
- Audit Trail und Evidence.

### 35.3 Testpyramide

Unit Tests für Transformationen und Regeln, Contract Tests für Connectoren, Integration Tests mit Mock Servern, End-to-End-Tests über kanonische Objekte und gezielte Sandbox-Tests mit echten Herstellerumgebungen.

## 36. Sandbox, Mocking und synthetische Demo-Welt

Der Prototyp benötigt eine vollständige, glaubwürdige Integrationswelt ohne produktive Kundendaten.

### 36.1 Mock Integration Hub

Ein interner Mock Hub simuliert:

- Microsoft Entra Identity-Änderungen,
- Defender Incidents und Alerts,
- Jira Issues und Webhooks,
- ServiceNow CIs, Incidents und Changes,
- AWS Security Findings,
- Dokument- und Evidence-Änderungen,
- Kalender- und Reiseereignisse,
- API-Fehler, Rate Limits und Schema Drift.

Mock-Endpunkte erzeugen reproduzierbare Szenarien, Signaturen, Pagination und Retry-Verhalten. Payloads orientieren sich strukturell an öffentlich dokumentierten APIs, enthalten aber ausschließlich synthetische Werte.

### 36.2 Demo-Umschaltung

Der Nutzer kann einen „Normalbetrieb“, „Audit in 30 Tagen“, „kritischer Incident“, „Identity-Ausfall“, „M&A Scope Change“ oder „Connector Degradation“ aktivieren. Die Plattform zeigt danach Events, Graph-Änderungen, Workflows, Morning Mission und Reports konsistent.

## 37. Benutzeroberflächen

### 37.1 Integration Catalog

Zeigt verfügbare Connectoren, Status, Fähigkeiten, erforderliche Berechtigungen, Datenobjekte, Schreibzugriffe, Prototyp-Tiefe und Einrichtungsaufwand.

### 37.2 Connection Wizard

Führt durch Zweck, Scope, Authentication, Capability, Test, Mapping, Preview, Freigabe und Aktivierung. Die Berechtigungsanforderung wird in Alltagssprache erklärt.

### 37.3 Mapping Studio

Zeigt Quelle und Ziel nebeneinander, Samples, Transformation, Match-Regel, Confidence, Konflikte und Graph-Preview. Änderungen können mit Testdaten ausgeführt werden.

### 37.4 Automation Studio

Bietet Blueprint-Bibliothek, Designer, Test Console, Diff, Rollout, Health und Wirkung. Ein Reviewer kann die Automation vollständig verstehen, ohne Code lesen zu müssen.

### 37.5 Operations Center

Verdichtet Connector Health, Workflow Failures, Dead Letters, Backlog, Frische, API Limits und betroffene Kunden. Es priorisiert nach Business- und Serviceauswirkung.

### 37.6 Object Provenance

Jede Objekt-360-Ansicht zeigt, welche Werte aus welchen Quellen stammen, wann sie aktualisiert wurden, welche Regel sie transformierte und ob ein Konflikt besteht.

## 38. KPIs und Anti-KPIs

### 38.1 Integrations-KPIs

| KPI                    | Aussage                                               |
|------------------------|-------------------------------------------------------|
| Connector Availability | technische Erreichbarkeit im vereinbarten Zeitfenster |
| Data Freshness         | Alter entscheidungsrelevanter Daten                   |
| Sync Success Rate      | erfolgreiche Jobs ohne kritische Reconciliation       |
| Event Processing Lag   | Zeit von Quelle bis kanonischer Wirkung               |
| Mapping Accuracy       | Anteil korrekt zugeordneter Felder und Objekte        |
| Reconciliation Backlog | offene Konflikte nach Alter und Auswirkung            |

| KPI                         | Aussage                                                          |
|-----------------------------|------------------------------------------------------------------|
| Schema Drift Detection Time | Zeit bis Erkennung inkompatibler Änderungen                      |
| Credential Health           | gültige, minimal berechnete und rechtzeitig rotierte Credentials |
| Dead-Letter Recovery Time   | Zeit bis kontrollierter Abschluss                                |
| Duplicate Prevention Rate   | verhinderte doppelte Objekte oder Aktionen                       |

## 38.2 Automatisierungs-KPIs

- Durchlaufzeit vor und nach Automation,
- manuelle Touchpoints,
- eingesparte Bearbeitungs- und Wartezeit,
- Fehler- und Rework-Rate,
- Approval Lead Time,
- Exception Rate,
- Automation Success Rate,
- kompensierte oder rückgerollte Läufe,
- realisierte Risiko- oder Qualitätswirkung,
- Nutzerakzeptanz und Override-Rate,
- Blueprint Reuse,
- Automation Debt.

## 38.3 Anti-KPIs

Nicht allein optimieren:

- Zahl der Connectoren,
- Zahl der API Calls,
- Zahl automatisierter Schritte,
- niedrigste mögliche Latenz,
- maximaler Datenbestand,
- Quote automatisch geschlossener Findings,
- Zahl verschickter Notifications,
- Workflow-Komplexität,
- „100 Prozent straight-through processing“ bei kritischen Entscheidungen.

# 39. End-to-End-Szenarien

## 39.1 Identity Change bis Reassignment

Entra meldet den Austritt eines Control Owners. Der Connector validiert Event und lädt den aktuellen User. Der Graph markiert die Person als inaktiv, identifiziert betroffene Controls, Risiken und offene Entscheidungen. Ein Workflow erstellt Reassignment Tasks für Primary und Backup Owner, informiert den ISMS Manager und blockiert kritische Freigaben, bis Verantwortung bestätigt ist.

## 39.2 Defender Incident bis Management-Entscheidung

Ein synthetischer Defender Incident betrifft zwei Assets. Die Plattform mappt sie auf den Geschäftsprozess „Kundenportal“, erkennt hohe Kritikalität, prüft bestehende Controls und erzeugt eine Decision Card. Ein Berater sieht Ursache, Evidence, Option A interne Behandlung und Option B Managed Incident Support. Keine Option wird automatisch gebucht.

## 39.3 Jira Ticket bis Control Assurance

Eine Maßnahme erzeugt ein Jira Ticket. Jira meldet „Done“. Die Plattform aktualisiert den Work-Item-Status, fordert jedoch Evidence und Control Test an. Erst nach Review verbessert sich die Control Effectiveness.

## 39.4 ServiceNow Change bis Scope Impact

Ein Change an einem zentralen Service wird importiert. Die Plattform erkennt neue Abhängigkeit zu einem regulierten Prozess, erstellt Scope Impact Assessment und leitet eine Review Route ein.

## 39.5 AWS Finding bis priorisierte Route

Ein Security Hub Finding wird über Event und späteren API-Abgleich verarbeitet. Es betrifft eine öffentlich erreichbare Ressource, die einen kritischen Prozess unterstützt. Die Zielroute wird neu berechnet; Morning Mission und Executive Change Story zeigen die Auswirkung.

## 39.6 Verlorener Webhook

Ein Jira Webhook wird simuliert verworfen. Der geplante Delta- oder Statusabgleich erkennt das veraltete Ticket, verarbeitet die Änderung idempotent und dokumentiert die verspätete Zustellung.



### 39.7 API-Rate-Limit

Eine Quelle liefert 429 und Retry-After. Der Connector reduziert Parallelität, priorisiert kritische Events und zeigt verzögerte Datenfrische. Keine falsche „aktuell“-Anzeige bleibt bestehen.

### 39.8 Schema Drift

Ein Hersteller ändert ein Enum. Contract Test und Runtime Validation erkennen die Abweichung, quarantänisieren betroffene Payloads und erzeugen einen Connector Change Case. Bestehende Daten bleiben unverändert.

## 40. Synthetische Demo-Szenen

1. Integration Catalog mit Entra, Defender, Jira, ServiceNow, AWS, Generic REST und Dateiimport öffnen.
2. Eine neue Connection im Wizard mit minimalen Scopes konfigurieren.
3. Connection Test und Berechtigungsübersicht anzeigen.
4. CSV/XLSX-Import mit Mapping Preview und drei Konflikten durchführen.
5. Defender Incident per signiertem Mock Webhook empfangen.
6. Event → Graph → Risiko → Morning Mission als Kausalitätskette zeigen.
7. Jira Ticket automatisch als Draft erzeugen und nach Human Gate absenden.
8. Doppelte Eventzustellung ohne doppelten Task demonstrieren.
9. Verlorenen Webhook durch Reconciliation erkennen.
10. Schema Drift und Quarantäne im Operations Center zeigen.
11. Workflow Blueprint „Audit 90/60/30“ für zwei Kunden konfigurieren.
12. Test Mode mit synthetischer Payload und Branch Coverage ausführen.
13. Workflow-Version vergleichen und gestaffelt ausrollen.
14. Connector-Ausfall mit sichtbarer Datenfrische und Business Impact simulieren.
15. Dead-Letter Item korrigieren und kontrolliert replayen.
16. Automatisierungswirkung mit eingesparter Zeit, Exceptions und Value Ledger zeigen.

## 41. Globale Akzeptanzkriterien

- **17-AC01:** Jede externe Information besitzt Quelle, externe ID, Abrufzeit, Contract- und Mapping-Version.
- **17-AC02:** Connectoren schreiben ausschließlich über kanonische Verträge in Produktobjekte.
- **17-AC03:** Mindestens Dateiimport, Generic REST, Webhook und ein Ticketing-Flow sind im Prototyp durchgängig funktionsfähig.
- **17-AC04:** Alle übrigen Demo-Connectoren können realistische, synthetische Payloads reproduzierbar verarbeiten.
- **17-AC05:** Read-only ist Standard; Schreibrechte werden separat aktiviert und sichtbar erklärt.
- **17-AC06:** Doppelte Events erzeugen keine doppelten Objekte, Tasks oder externen Aktionen.
- **17-AC07:** Verlorene kritische Webhooks können durch einen Reconciliation-Pfad erkannt werden.
- **17-AC08:** Mapping Preview zeigt erwartete Objekte, Relationships, Konflikte und verworfene Felder.
- **17-AC09:** Unsichere Matches erzeugen Reconciliation Cases statt automatische Merges.
- **17-AC10:** Jede Automation ist versioniert, testbar, pausierbar und einem Owner zugeordnet.
- **17-AC11:** Kritische oder irreversible Aktionen benötigen konfiguriertes Human Gate.
- **17-AC12:** „Done“ in einem Fremdsystem schließt kein Risiko oder Control ohne fachliche Prüfung.
- **17-AC13:** Connector Health zeigt Frische, Fehler, Rate Limits, Subscription, Drift und Backlog.
- **17-AC14:** Fehlerhafte Payloads können quarantänisiert, korrigiert und kontrolliert replayed werden.
- **17-AC15:** Workflows setzen nach System- oder Worker-Ausfall am letzten sicheren Checkpoint fort.
- **17-AC16:** Ein Connector kann pausiert, Credentials können widerrufen und die Connection kann geordnet retired werden.
- **17-AC17:** Staging-Rohdaten unterliegen Retention, Maskierung und Mandantentrennung.
- **17-AC18:** Data Contracts und Eventschemas sind maschinenlesbar und versioniert.
- **17-AC19:** API Limits und Datenfrische werden nicht versteckt.
- **17-AC20:** Alle externen Schreibaktionen sind mit Request, Response, externer ID und Ergebnis auditierbar.
- **17-AC21:** Blueprint-Vererbung schützt verpflichtende Gates und dokumentiert kundenspezifische Abweichungen.
- **17-AC22:** Demo-Szenarien benötigen keine produktiven Credentials oder internen Beratungsdaten.
- **17-AC23:** Ein Nutzer kann für jedes importierte Feld Provenance und Transformation nachvollziehen.
- **17-AC24:** Automation Impact misst nicht nur Anzahl der Läufe, sondern Zeit, Qualität, Risiko und Exception Rate.

## 42. Festgelegte Entscheidungen

- **17-D01:** Die Plattform wird Integrations- und Entscheidungsschicht, nicht pauschaler Ersatz bestehender Quellsysteme.
- **17-D02:** Alle Connectoren arbeiten über kanonische Data Contracts und Objekte aus Dokument 07.
- **17-D03:** Rohquelle, Mapping, Confidence und Historie bleiben nachvollziehbar.
- **17-D04:** Unterstützte Muster sind manuell, Dateiimport, Full Sync, Delta Sync, Webhook und Streaming.
- **17-D05:** Für kritische Webhooks wird ein Reconciliation-Fallback vorgesehen.
- **17-D06:** Interne Eventverarbeitung ist idempotent und correlation-/causation-fähig.
- **17-D07:** Read-only ist Default; externe Schreibaktionen werden nach Risikoklasse freigegeben.

- **17-D08:** Workflows sind versionierte Produktobjekte mit Test, Owner, Human Gates und Recovery.
- **17-D09:** Deterministische Automation, Empfehlung, KI-Assistenz und menschliche Entscheidung bleiben getrennt.
- **17-D10:** Berater können geprüfte Blueprints über Mandanten wiederverwenden; kundenspezifische Overlays bleiben sichtbar.
- **17-D11:** Der Prototyp implementiert einen Mock Integration Hub mit reproduzierbaren Ereignissen und Fehlerfällen.
- **17-D12:** Dateimport und Generic REST Connector sind strategische Kernfunktionen, nicht nur Notlösungen.
- **17-D13:** Identity-, Ticketing- und Security-Connectoren erhalten höchste Prototyp-Priorität.
- **17-D14:** „Done“ oder „Resolved“ in einem Fremdsystem ist nur ein Signal und keine automatische Wirksamkeitsbestätigung.
- **17-D15:** Connector Health wird nach technischer und fachlicher Auswirkung priorisiert.
- **17-D16:** OpenAPI-orientierte HTTP-Verträge, AsyncAPI-orientierte Eventverträge und ein CloudEvents-orientiertes Envelope dienen als Standardrichtung.
- **17-D17:** OAuth- und SCIM-Integrationen berücksichtigen aktuelle Sicherheits- und Protokollstandards.
- **17-D18:** Produktive Credentials, Kundendaten und interne Beratungsvorlagen sind in Demo und Repository verboten.
- **17-D19:** Automatisierungserfolg wird an Wirkung und Fehlerreduktion gemessen, nicht an Menge.
- **17-D20:** Jeder langlaufende Workflow besitzt persistente Checkpoints und kann über Sessions hinweg fortgesetzt werden.

## 43. Begründete Annahmen

- **17-A01:** Zielkunden nutzen heterogene Toolandschaften und benötigen daher mehrere Integrationsmuster.
- **17-A02:** Viele frühe Pilotkunden können mit Dateimporten und wenigen Kernconnectoren einen hohen Nutzen erreichen.
- **17-A03:** Webhooks sind nicht in jeder Umgebung vollständig zuverlässig und benötigen Reconciliation.
- **17-A04:** Hersteller-APIs ändern Versionen, Schemas, Quoten und Lizenzvoraussetzungen regelmäßig.
- **17-A05:** Ein kanonisches Modell reduziert langfristig Integrationskomplexität stärker als direkte Punkt-zu-Punkt-Kopplung.
- **17-A06:** Berater akzeptieren Automatisierung eher, wenn Regel, Datenbasis und Ausnahme sichtbar sind.
- **17-A07:** Kunden verlangen bei externen Schreibaktionen strengere Freigaben als bei internen Drafts und Notifications.
- **17-A08:** Ein großer Teil wiederkehrender Managed-Service-Arbeit lässt sich als Blueprint standardisieren.
- **17-A09:** Nicht jede Automation benötigt KI; deterministische Regeln liefern für viele Kernprozesse höhere Verlässlichkeit.
- **17-A10:** Ein Mock Integration Hub reicht für die erste überzeugende Produktdemo, wenn End-to-End-Wirkung realistisch ist.
- **17-A11:** Für produktive Nutzung werden je nach Kunde private Netzwerke, regionale Endpoints oder On-Premises Agents benötigt.
- **17-A12:** Connectorbetrieb erzeugt relevante laufende Kosten und muss in Service- und Preismodellen berücksichtigt werden.

## 44. Offene Fragen

- **17-Q01:** Welche drei Herstellerconnectoren werden zusätzlich zu Generic REST und Dateimport im ersten technischen Build real angebunden?
- **17-Q02:** Welche Hersteller-Sandboxen und API-Lizenzen stehen für Entwicklung und Demo zur Verfügung?
- **17-Q03:** Wird ein selbst betriebener Integration Worker für private Kundennetze benötigt?
- **17-Q04:** Welche Rohpayloads müssen gespeichert werden und welche dürfen nach Mapping sofort gelöscht werden?
- **17-Q05:** Wie lange bleiben Dead Letters, Event Replay und Import Rollback verfügbar?
- **17-Q06:** Welches interne Event- und Workflow-Laufzeitprodukt wird in Dokument 18 gewählt?
- **17-Q07:** Welche OpenAPI-/AsyncAPI-Versionen und Schemaformate werden als verbindlicher Engineering-Standard festgelegt?
- **17-Q08:** Welche Connectoren dürfen bidirektional schreiben und welche bleiben dauerhaft read-only?
- **17-Q09:** Welche Datenfelder aus HR- und Identity-Systemen sind datenschutzrechtlich erforderlich und zulässig?
- **17-Q10:** Wie werden kundenspezifische Netzwerkrestriktionen, Proxies und Zertifikate verwaltet?
- **17-Q11:** Welche Rate-Limit- und API-Kosten werden je Connector in Preis und SLA berücksichtigt?
- **17-Q12:** Welche Workflow-Schritte dürfen Kunden selbst erstellen und welche nur Provider-Administratoren?
- **17-Q13:** Welche Blueprint-Änderungen benötigen erneute Kundenfreigabe?
- **17-Q14:** Wie wird die Migration eines Connector-Major-Releases ohne lange Unterbrechung umgesetzt?
- **17-Q15:** Welche Observability-Daten dürfen Provider-Supportrollen mandantenübergreifend sehen?
- **17-Q16:** Welche Connector- und Workflow-Zertifizierung ist für einen späteren Marketplace erforderlich?
- **17-Q17:** Welche Mobile- oder Offline-Integrationen werden für Vor-Ort-Audits benötigt?
- **17-Q18:** Welche externen Systeme gelten je Objekt und Attribut als System of Record?

## 45. Ideen für später

- Connector Marketplace mit signierten, geprüften Paketen,
- Self-Service Connector Builder aus OpenAPI-Beschreibungen,
- AI-assisted Mapping mit menschlicher Bestätigung,
- automatische API-Drift-Analyse und Migrationsvorschläge,
- private Edge Connector Appliance für isolierte Kundennetze,
- anonymisierte Connector Reliability Benchmarks,
- Workflow Mining aus realen Beraterabläufen,
- Simulation von Automation ROI vor Aktivierung,
- automatische Erkennung zyklischer oder widersprüchlicher Workflows,
- Policy-as-Code- und Infrastructure-as-Code-Integrationen,

- Security Orchestration für klar begrenzte reversible Maßnahmen,
- Event Replay Time Machine für Audits und Root Cause Analysis,
- branchenbezogene Connector Packs,
- standardisierte Evidence Packs aus technischen Quellen,
- Workflow Copilot, der nur freigegebene Bausteine kombiniert,
- kundenindividuelle Automation Budgets und Rate-Limit-Steuerung,
- digital signierte Connector Attestations,
- OpenTelemetry-basierte End-to-End-Traces für Integrationsläufe.

## 46. Dokumentenabhängigkeiten

### 46.1 Eingehende Abhängigkeiten

- **Dokument 00:** Projektverfassung, Status, zentrale Wahrheit und Änderungsregeln.
- **Dokument 01:** Produktvision, Skalierung und messbarer Managed-Service-Nutzen.
- **Dokument 02:** Wettbewerbs- und Integrationslandschaft.
- **Dokument 03:** Rollen, Administratoren, Berater, Kunden und Auditoren.
- **Dokument 04:** End-to-End-Journeys und Lifecycle-Ereignisse.
- **Dokument 05:** Module, Integrations- und Automatisierungsumfang.
- **Dokument 06:** UI-Prinzipien, Integration Catalog, Operations Center und progressive Bedienung.
- **Dokument 07:** kanonische Objekte, Graph, Provenance, Identity und Historie.
- **Dokument 08:** ISMS-Kernprozesse, Freigaben und fachliche Statuslogik.
- **Dokument 09:** Risiko-, Threat-, Reife-, Control- und Confidence-Logik.
- **Dokument 10:** Decision Center, KPI, Route und Simulation.
- **Dokument 11:** Work Items, Human Gates, Collaboration und Handover.
- **Dokument 12:** Report- und Evidence-Ausgaben.
- **Dokument 13:** Managed-Service-Lifecycle, Quality Gates und Operations.
- **Dokument 14:** Servicekatalog, SLA, Kosten und Fair Use.
- **Dokument 15:** Kapazität, Reise, PSA und Portfolio.
- **Dokument 16:** Onboarding, Import Batches, Strategy DNA, Baseline und Lifecycle Events.

### 46.2 Ausgehende Abhängigkeiten

- **Dokument 18:** legt Laufzeitarchitektur, Queue/Event Bus, Workflow Engine, Connector Worker, Datenbanken, Deployment, Observability und Skalierung fest.
- **Dokument 19:** konkretisiert Secret Management, Mandantentrennung, Rechte, Datenklassifikation, Audit Logs, Egress, Retention und Incident Response.
- **Dokument 20A:** definiert KI-Unterstützung für Mapping, Zusammenfassung, Anomalieerkennung, Workflow-Vorschläge und Guardrails.
- **Dokument 20B:** weist Agentenrollen für Connector Engineering, Data Contracts, Security, QA, Operations und Documentation zu.
- **Dokument 20C:** implementiert Connectoren und Workflows modular, checkpointfähig, contract-tested und mit synthetischen Mock-Systemen.

### 46.3 Änderungsregel

Änderungen an Connector-, Connection-, Data-Contract-, Mapping-, Event-, Workflow-, Human-Gate-, Health- oder Retry-Semantik benötigen eine versionierte Impactanalyse gegen Dokument 07 bis 20C. Änderungen an kanonischen Objekten werden nicht ausschließlich in diesem Dokument vorgenommen, sondern müssen mit Dokument 07 abgestimmt und im Master-Index dokumentiert werden.

## 47. Öffentliche Referenzquellen

Die folgenden offiziellen Quellen dienen als technische Plausibilitäts- und Standardanker. Sie definieren nicht automatisch den finalen Produktstack und ersetzen keine Lizenz-, Datenschutz- oder Architekturprüfung.

- **S1 – Microsoft Graph Change Notifications:** Webhook-basierte Change Notifications und Subscription-Renewal.  
<https://learn.microsoft.com/en-us/graph/change-notifications-delivery-webhooks>
- **S2 – Microsoft Graph Delta Query:** inkrementelle Synchronisation von Ressourcen.  
<https://learn.microsoft.com/en-us/graph/delta-query-overview>
- **S3 – Microsoft Defender XDR APIs:** Incident-, Advanced-Hunting- und Streaming-Funktionen.  
<https://learn.microsoft.com/en-us/defender-xdr/api-overview>
- **S4 – Jira Cloud Webhooks:** dynamische Webhooks und REST-Verwaltung.  
<https://developer.atlassian.com/cloud/jira/platform/rest/v3/api-group-webhooks/>
- **S5 – ServiceNow REST APIs:** Table API, REST API Explorer und Scripted REST APIs.  
[https://www.servicenow.com/docs/r/api-reference/rest-api-explorer/c\\_RESTAPI.html](https://www.servicenow.com/docs/r/api-reference/rest-api-explorer/c_RESTAPI.html)
- **S6 – AWS Security Hub:** Findings-Import und EventBridge-Ereignisse.  
<https://docs.aws.amazon.com/securityhub/latest/userguide/finding-update-batchimportfindings.html>
- **S7 – GitHub Webhooks:** signierte Ereigniszustellung, Delivery-Status und Redelivery.  
<https://docs.github.com/en/webhooks/about-webhooks>

- **S8 – SCIM Protocol:** standardisierte HTTP-basierte Verwaltung von Usern und Gruppen.  
<https://www.rfc-editor.org/info/rfc7644/>
- **S9 – OAuth 2.0 Security BCP:** aktuelle Sicherheitsempfehlungen für OAuth 2.0. <https://www.rfc-editor.org/info/rfc9700/>
- **S10 – OpenAPI Specification:** maschinenlesbare Beschreibung von HTTP-APIs. <https://spec.openapis.org/oas/latest.html>
- **S11 – AsyncAPI Specification:** Beschreibung asynchroner und eventgetriebener APIs.  
<https://www.asyncapi.com/docs/reference/specification/v3.1.0>
- **S12 – CloudEvents:** standardisiertes, protokollunabhängiges Event-Metadatenmodell.  
<https://www.cncf.io/projects/cloudevents/>

## 48. Änderungsprotokoll

| Version | Datum      | Änderung                                                                                                                                                                                                   | Status   |
|---------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| 1.0     | 22.07.2026 | Erstfassung für Connectoren, Data Contracts, Synchronisation, Events, Reconciliation, Workflow-Designer, Automation Blueprints, Human Gates, Connector Operations, Mock Integration Hub und Demo-Szenarien | Erstellt |